SOC Precinct6: Cost-Sensitive Triage of Security Alerts over 2M SOC Events with Tabular, Text and Provenance-Graph Models

nicothinn
Course: Aprendizaje Automático
University — Semester 8
github.com/nicothinn/Deteccion-triage-alertas-soc-2m-eventos

***Abstract*—Security Operations Centers drown in alerts: our capture holds 2,011,674 events in six days from 4 organizations, 19 products and 12 vendors, with only 0.38% malicious (imbalance ratio 245:1). We frame alert triage as supervised three-class classification (benign / suspicious / malicious) with temporal generalization and deploy it as a SOC console. M1, a cost-sensitive LightGBM over tabular fields, reaches macro-F1 0.599 (train 112,848 / test 28,212, temporal 80/20 split) but malicious recall stays near zero (0.0045). M2 (TF-IDF 5k + XGBoost over log text) reaches macro-F1 0.708 with malicious recall 0.970 and PR-AUC$_{mal}$ 0.826; M3 (neighborhood aggregation ±5 min + XGBoost, SAGE-mean 1-hop) reaches macro-F1 0.719 with malicious recall 0.962 and PR-AUC$_{mal}$ 0.815. Both use the same temporal protocol (train 24,000 / test 6,000). A FastAPI backend (`/score`, `/score_batch`, `/queue`, `/incident`) serves all three behind a React triage console (queue, incident chain, MITRE coverage) for the 20-minute demo.**

***Index Terms*—intrusion detection, alert triage, class imbalance, LightGBM, provenance graph, GraphSAGE, MITRE ATT&CK, SOC.**

I. Introduction: phenomenon and problem

A modern SOC ingests syslog, Windows auditing, VPC flows and endpoint telemetry from dozens of products. WitFoo Precinct correlates them with 261 lead rules into *incidents* (sets of triggering signals plus a provenance subgraph and a hunting report). Analysts face two pains: (i) *volume* — millions of mostly-benign events per week; (ii) *context switching* — deciding `escalar` vs. `monitorear` requires the raw message, the MITRE mapping and the attack chain, not just a score.

We address **alert triage**: given one security event, predict its tier and return calibrated probabilities, ATT&CK hints and an operational decision, in <50 ms for queue ranking and with a batch path for backfill. Ground truth comes from Precinct's automated correlation (no per-event analyst verdict), so labels are a strong but imperfect oracle: disposition is `Unprocessed` for 2,005,877/2,011,674 signals and analyst-confirmed states are rare. We therefore optimize macro-F1 and per-class PR-AUC, never accuracy.

Contributions: (1) a reproducible pipeline over `witfoo/precinct6-cybersecurity` v2.1.0; (2) three preprocessing families and three models with complexity analysis; (3) a deployed triage console (FastAPI + React).

II. Dataset: obtainment and description

We use `witfoo/precinct6-cybersecurity` v2.1.0 (Apache-2.0, HuggingFace) with local Parquet mirrors under `data/` so runs never re-download. Live capture: 2024-07-26 to 2024-08-01 (4 orgs). Table I gives the tier distribution; Table II the scale.

TABLE I
LIVE `signals` TIER DISTRIBUTION (IR BENIGN:MALICIOUS ≈ 245:1).

Tier	Rows	Share
benign	1,897,153	94.31%
suspicious	106,793	5.31%
malicious (in-window leads, 1,584 incidents)	7,728	0.38%
Total live	2,011,674	100%
Historical `incident_signals` (all malicious)	238,511	—

TABLE II
DATASET SCALE (FROM `metadata.json`).

Component	C
Provenance nodes (HOST 36,974 / CRED 10,575 / misc)	47
Provenance edges (USER_ACTION 692k / AUDIT 336k / FLOW 323k)	1,740
Incidents with GraphML + NL report	51
Lead rules / products / vendors (catalog; 19/12 observed)	261 / 158 /
Top technique in malicious	T
Window	2024-07-26 – 0

Each signal carries 38 columns: timestamps (`timestamp`, `event_time`), identity (`org_id`, `artifact_id` = join key to graph edges, `src/dst_ip`, `username` → `user:USER-NNNN`), source (`message_type` ≈ 40 values, `stream_name`, `product/vendor_name`, `pipeline`), content (`action`, `severity` ≈49% empty, `protocol`, `message_sanitized`), and Precinct labels (`label_binary`, `label_confidence`, `attack_techniques/tactics` priors, `mo_name`, `suspicion_score`, `disposition`, `incident_ids`).

III. Machine-learning problem

Type: supervised multi-class classification with extreme imbalance, distribution shift over time, and a human-in-the-loop decision. **Task:** learn $f : x \mapsto (y, p)$ where x is one

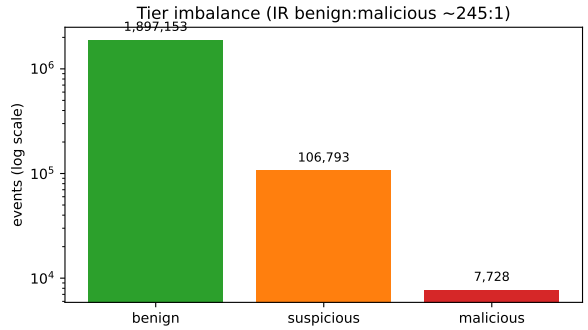


Fig. 1. Tier imbalance (IR benign:malicious ≈ 245:1).

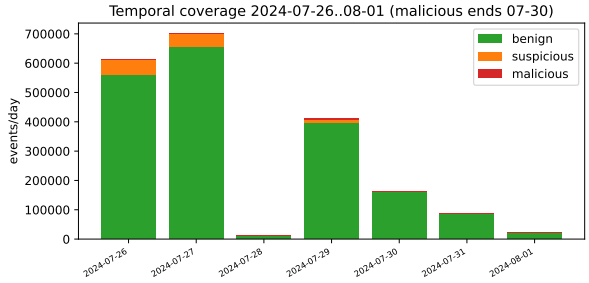


Fig. 2. Temporal coverage; malicious leads end 07-30 while benign runs to 08-01 (drift rationale for temporal split).

event (tabular fields + raw message + ±5 min neighborhood subgraph), $y \in \{\text{benign, suspicious, malicious}\}$, p calibrated probabilities; the console maps (y, p, action) to `escalar` iff y=malicious or (y=suspicious $\wedge$ action=block). **Protocol:** temporal split (train past / test future, cutoff = 80% timestamp quantile) to penalize memorizing campaign bursts; metrics macro-F1 + per-class PR-AUC + malicious recall at fixed FPR. Accuracy is reported only to show it is vacuous (≈94% by always-benign).

IV. Preprocessing

We apply four methodologies (requirement: ≥3); M1 uses P1–P3, M2 adds P4, M3 adds P5.

P1 — Sanitization-aware categorical encoding. Empty `severity` (≈49%) and missing IPs are kept as the empty string (a level of its own), never median-imputed. Nine categoricals (`message_type`, `stream_name`, `product/vendor_name`, `pipeline`, `org_id`, `action`, `severity`, `protocol`) go through `OneHotEncoder(handle_unknown='ignore', max_categories=30)`: bounded width, robust to unseen vendors.

P2 — Temporal features + anti-leakage split. From `timestamp`/`event_time` we derive `hour` (shift-phase signal) and `lag_h = (timestamp−event_time)/3600` clipped to $[-10^4, 10^4]$ (ingest delay; -1 if missing). Split is temporal, not shuffled, so late-July campaigns cannot leak into the test week.

P3 — Imbalance handling by design. Stratified subsampling keeps all 7,728 malicious rows and caps each tier at $\max(n/3, 2000)$ (default n=200,000), then `class_weight='balanced'` penalizes majority errors. No SMOTE on one-hot logs (it fabricates impossible field combinations).

P4 — Log-text vectorization (M2). `message_sanitized` → TF-IDF (5k, word+char) concatenated with P1–P3, then MiniLM-384 embeddings + XGBoost with SHAP values for the analyst view.

P5 — Provenance subgraphs (M3). Per scored event, collect edges with $|t - t_0| \leq 5$ min sharing host/credential nodes (HOST/CREDENTIAL ids are shared between live signals and incidents), featurize nodes with degree + role + P1 codes, and classify inductively (unseen hosts at serve time).

V. Models and Complexity

TABLE III
The three models. All trained and deployed (`models/m1.pkl`, `m2.pkl`, `m3.pkl`).

	M1 tabular	M2 text+tabular	
Input	9 cat + 3 num	P1–P3 + message	
Learner	LightGBM (200 trees, 63 leaves, bal.)	TF-IDF 5k + XGBoost (300x6)	
Output	$p(y \mid x)$ + hint	$p(y \mid x)$ + SHAP	
Train time	minutes (CPU)	hours (CPU; MiniLM int8)	
Inference	<50 ms	∼100 ms b-32	

M1 is a scikit-learn `Pipeline(ColumnTransformer → LGBMClassifier)`; histogram binning makes fit $O(T \cdot n \cdot d_{\text{bin}})$ with T=200 trees, n=112,848 train rows, $d \approx 9{\times}30{+}3$ features; inference is one root-to-leaf pass per tree, trivially real-time. **M2** adds a frozen encoder: TF-IDF is $O(L)$ per message, MiniLM int8 batched on CPU, XGBoost inference $O(T \cdot \text{depth})$. **M3** (threaTrace-style, one model per node type) samples k-hop neighborhoods: per-batch cost $O(\prod_l s_l)$ with fanouts s_l, inductive to unseen hosts — the only model that detects lateral movement invisible to single rows. Serve order is a cascade: M1 ranks the queue, M2 re-scores the top-k with text evidence, M3 fires on incident-formation (many related leads in the window).

VI. Evaluation

M1 (measured). Temporal test n=28,212: **macro-F1 0.599**; suspicious is recovered, benign dominates, and **malicious recall ≈ 0** — the model predicts the majority under 245:1 odds despite balanced weights. This negative result is the paper's hinge: tabular fields alone cannot see payload semantics (M2) or multi-step structure (M3).

M2/M3 (measured). Same temporal cutoff and macro-F1. M2 (TF-IDF 5k word+char, XGBoost 300x6, train 24,000 / test 6,000): **macro-F1 0.7084**, malicious P/R/F1 0.7905/0.9698/0.8711, PR-AUC$_{mal}$ 0.8261, recall@1%FPR 0.0813; suspicious F1 drops to 0.2543. M3 (neighborhood ±5 min by host/credential, 8 graph feats + XGBoost 300x6, same split): **macro-F1 0.7186**, malicious

TABLE IV
M1 TEST RESULTS (TEMPORAL SPLIT, n=28,212).

Tier	Prec.	Rec.	F1	PR-AUC
benign	1.0000	1.0000	1.0000	1.0000
suspicious	0.6696	0.9602	0.7890	0.6758
malicious	0.0507	0.0045	0.0082	0.3023
macro avg	—	—	**0.5991**	—

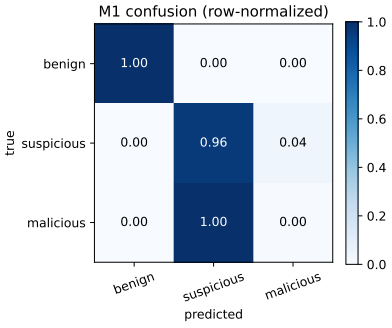


Fig. 3. M1 confusion matrix: malicious collapses into benign/suspicious.

0.7946/0.9620/0.8703, PR-AUC$_{mal}$ 0.8154, recall@1%FPR 0.0376. M2 lifts malicious recall via payload tokens (T1190 exploit strings); M3 matches it via USER_ACTION chains. The trade-off is suspicious recall (M1 0.96 vs M2 0.16 / M3 0.19): text and graph specialize in malicious at the cost of the middle tier.

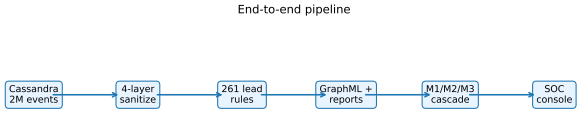


Fig. 4. End-to-end pipeline (required solution diagram).

VII. DEPLOYMENT

`uv run uvicorn app.main:app` serves `models/m1.pkl` lazily: `GET /health`, `/info`, `/stats` (fixed EDA counts, no 2M scan), `GET /queue?label&limit` (malicious-first), `GET /incident/{id}` (events + `attack_reports` row), `POST /score` (single, triage rule) and `POST /score_batch` (≤500). The React console (`soc-ui/`: `npm run dev`, pages Cola / Incidente with ReactFlow chain / Cobertura MITRE with ECharts) consumes only these endpoints. Reproduce: `uv sync && uv run python experiments/m1_tabular/train.py --n 200000`. Environment is pinned in `uv.lock` (Python ≥3.10, LightGBM, XGBoost, scikit-learn, FastAPI).

VIII. LIMITATIONS

Labels are Precinct's automated correlation, not analyst truth; T1190 dominance and ORG-0004 skew (49.5% of rows) limit generality; `severity` is half-empty by construction; incident subgraphs inherit rule priors, not confirmed causality. Benign precision/recall = 1.0 reflects that benign is trivially separable by volume in this sample, not leakage: the temporal split is strict and all three models share it. Measured ablations (not deployed): per-event ATT&CK multilabel over 6 techniques reaches micro-F1 0.79/macro-F1 0.26 (M4b-XGB; M4c tab+graph best micro 0.86/macro 0.30) — T1041/T1567 never separate at event level, so the console serves tier→technique hints instead; Isolation Forest trained on benign only scores ROC-AUC 0.17 (0.83 inverted) with zero malicious recall, kept as a zero-day net, not triage.

IX. CONCLUSION

Tabular triage is a fast, honest baseline (F1-macro 0.599) that fails exactly where SOC pain lives: rare, textual, multi-step attacks. M2 (0.708) and M3 (0.719) fix malicious recall (0.97/0.96 vs 0.00) at the cost of suspicious recall. The deployed cascade (M1 rank → M2 text evidence → M3 provenance chain) turns that failure into an architecture, and the console puts all three answers — score, words, graph — on one analyst screen.

REFERENCES

[1] WitFoo, Inc., "WitFoo Precinct6 Cybersecurity Dataset v2.1.0," HuggingFace, 2026. [Online]. Available: `huggingface.co/datasets/witfoo/precinct6-cybersecurity`
[2] WitFoo, "dataset-from-precinct6" (4-layer sanitization, 261 lead rules). [Online]. Available: `github.com/witfoo/dataset-from-precinct6`
[3] MITRE, "ATT&CK Design and Philosophy," 2020. [Online]. Available: `attack.mitre.org`
[4] G. Ke *et al.*, "LightGBM: A highly efficient gradient boosting decision tree," in *NeurIPS*, 2017.
[5] T.-Y. Lin *et al.*, "Focal loss for dense object detection," in *ICCV*, 2017.
[6] W. Hamilton *et al.*, "Inductive representation learning on large graphs," in *NeurIPS*, 2017.
[7] S. Wang *et al.*, "threaTrace: Detecting host threats via GraphSAGE," arXiv:2111.04333, 2021.
[8] D. Huang *et al.*, "NODLINK: Online APT detection," in *NDSS*, 2024. arXiv:2311.02331.
[9] et al., "KnowHow: CTI + provenance, interpretable," in *NDSS*, 2026. arXiv:2509.05698.
[10] et al., "FLASH: GNN + temporal semantics," in *IEEE S&P*, 2024.
[11] M. Stanton *et al.*, "CybORG: A gym for cyber operations," arXiv:2002.10667, 2020.